

Digital Policy Office

INFORMATION SECURITY

Practice Guide

for

Security Practices on IT Outsourcing

Version 1.2

July 2024

© The Government of the Hong Kong Special Administrative Region
of the People's Republic of China

The contents of this document remain the property of and may not be reproduced in whole or in part without the express permission of the Government of the HKSAR.
--

COPYRIGHT NOTICE

© 2024 by the Government of the Hong Kong Special Administrative Region of the People's Republic of China

Unless otherwise indicated, the copyright in the works contained in this publication is owned by the Government of the Hong Kong Special Administrative Region of the People's Republic of China. You may generally copy and distribute these materials in any format or medium provided the following conditions are met –

- (a) the particular item has not been specifically indicated to be excluded and is therefore not to be copied or distributed;
- (b) the copying is not done for the purpose of creating copies for sale;
- (c) the materials must be reproduced accurately and must not be used in a misleading context; and
- (d) the copies shall be accompanied by the words “copied/distributed with the permission of the Government of the Hong Kong Special Administrative Region of the People's Republic of China. All rights reserved.”

If you wish to make copies for purposes other than that permitted above, you should seek permission by contacting the Digital Policy Office.

Amendment History				
Change Number	Revision Description	Pages Affected	Revision Number	Date
1	Revised in accordance with the updated Government IT security related documents.	Whole document	1.1	June 2021
2	Change “Office of the Government Chief Information Officer” (or “OGCIO”) to “Digital Policy Office” (or “DPO”)		1.2	July 2024

Table of Contents

1. Introduction.....	1
1.1 Purpose.....	1
1.2 Normative References.....	1
1.3 Terms and Convention.....	1
1.4 Contacts.....	2
2. Information Security Management.....	3
3. Development Stage.....	5
4. Formalisation Stage	6
5. Monitoring Stage.....	8
6. Transition Stage	9

1. Introduction

IT outsourcing means the subcontracting of partly or all IT functions of an organisation to one or more external vendors. The degree of subcontracting depends on the business needs, the availability of manpower resources and the technologies required. It is important to note that a Bureau / Department (B/D) can outsource its IT activities to third parties, but not its responsibilities. B/Ds are fully responsible for the governance, compliance and risk management of the project or service outsourced.

1.1 Purpose

This Practice Guide highlights the areas in information security that should be considered in IT outsourcing at different stages of a contract lifecycle:

- Development stage
- Formalisation stage
- Monitoring stage
- Transition stage

1.2 Normative References

The following reference documents are indispensable for the application of this document.

- Baseline IT Security Policy [S17], the Government of Hong Kong Special Administrative Region
- IT Security Guidelines [G3], the Government of Hong Kong Special Administrative Region
- Terms and Conditions of SOA-QPS4
http://www.itginfo.gov.hk/content/contract/qps4/qps_acquisition.asp

1.3 Terms and Convention

For the purposes of this document, the terms and convention given in S17, G3, and the following apply.

Abbreviation and Terms	
NA	NA

1.4 Contacts

This document is produced and maintained by the Digital Policy Office (DPO). For comments or suggestions, please send to:

Email: it_security@digitalpolicy.gov.hk

Lotus Notes mail: [IT Security Team/DPO/HKSARG@DPO](mailto:IT_Security_Team/DPO/HKSARG@DPO)

CMMP mail: [IT Security Team/DPO](mailto:IT_Security_Team/DPO)

2. Information Security Management

Information security is about the planning, implementation and continuous enhancement of security controls and measures to protect the confidentiality, integrity and availability of information assets, whether in storage, processing, or transmission and its associated information systems. Information security management is a set of principles relating to the functions of planning, organising, directing, controlling, and the application of these principles in harnessing physical, financial, human and informational resources efficiently and effectively to assure the safety of information assets and information systems.

Information security management involves a series of activities that require continuous monitoring and control. These activities include but not limited to the following functional areas:

- Security Management Framework and the Organisation;
- Governance, Risk Management, and Compliance;
- Security Operations;
- Security Event and Incident Management;
- Awareness Training and Capability Building; and
- Situational Awareness and Information Sharing.

Security Management Framework and Organisation

B/Ds shall establish and enforce departmental information security policies, standards, guidelines and procedures in accordance with the business needs and the government security requirements.

B/Ds shall also define the organisation structure on information security and provide clear definitions and proper assignment of security accountability and responsibility to involved parties.

Governance, Risk Management and Compliance

B/Ds shall adopt a risk-based approach to identify, prioritise and address the security risks of information systems in a consistent and effective manner.

B/Ds shall perform security risk assessments for information systems and production applications periodically and when necessary so as to identify risks and consequences associated with vulnerabilities, and to provide a basis to establish a cost-effective security program and implement appropriate security protection and safeguards.

B/Ds shall also perform security audit on information systems regularly to ensure that current security measures comply with departmental information security policies, standards, and other contractual or legal requirements.

Security Operations

To protect information assets and information systems, B/Ds should implement comprehensive security measures based on their business needs, covering different technological areas in their business, and adopt the principle of "Prevent, Detect, Respond and Recover" in their daily operations.

- Preventive measures avoid or deter the occurrence of an undesirable event;
- Detective measures identify the occurrence of an undesirable event;
- Response measures refer to coordinated actions to contain damage when an undesirable event or incident occurs; and
- Recovery measures are for restoring the confidentiality, integrity and availability of information systems to their expected state.

Security Event and Incident Management

In reality, security incidents might still occur due to unforeseeable, disruptive events. In cases where security events compromise business continuity or give rise to risk of data security, B/Ds shall activate their standing incident management plan to identifying, managing, recording, and analysing security threats, attacks, or incidents in real-time. B/Ds should also prepare to communicate appropriately with relevant parties by sharing information on response for security risks to subdue distrust or unnecessary speculation. When developing an incident management plan, B/Ds should plan and prepare the right resources as well as develop the procedures to address necessary follow-up investigations.

Awareness Training and Capability Building

As information security is everyone's business, B/Ds should continuously promote information security awareness throughout the organisations and arrange training and education to ensure that all related parties understand the risks, observe the security regulations and requirements, and conform to security best practices.

Situational Awareness and Information Sharing

As cyber threat landscape is constantly changing, B/Ds should also constantly attend to current vulnerabilities information, threat alerts, and important notices disseminated by the security industry and the GovCERT.HK. The security alerts on impending and actual threats should be disseminated to and shared with those responsible colleagues within B/Ds so that timely mitigation measures could be taken.

B/Ds could make use of threat intelligence platforms to receive and share information regarding security issues, vulnerabilities, and cyber threat intelligence.

3. Development Stage

Before an outsourcing arrangement is established, B/Ds should carefully plan and incorporate IT security requirements in IT projects or services. The roles and responsibilities of B/Ds and the service provider should be clearly defined and reviewed.

- (i) Establish an appropriate internal information security management team to oversee the strategy and formulate the requirements on IT outsourcing.
- (ii) Before the decision is made to commence the IT outsourcing process, potential risks should be assessed. Ensure that IT security requirements are identified while potential outsourcing vendors should understand the risk they are expected and contracted to manage.
- (iii) Clearly define the business processes and functions of the outsourced information systems. For each business process or system, identify the specific governance, regulatory or compliance standards and requirements.
- (iv) Review security threats, vulnerabilities and security status of existing business process or system before they are outsourced.
- (v) Define the scope and boundaries of IT functions / activities, and then specify the security requirements of the IT functions / activities to be outsourced on the contract, such as the sensitivity level or how to handle personal data.
- (vi) Carry out business impact analysis and security risk assessments before outsourcing. It is better to articulate security requirements and communicate with the outsourcing service provider as early as possible.
- (vii) Observe and be aware of the possible impact of the regulatory frameworks in other economies (e.g. The Personal Information Protection Law (PIPL) of the People's Republic of China, GDPR, US CLOUD Act).

4. Formalisation Stage

Formalisation involves turning specific requirements into contractual terms. B/Ds should carefully craft the contract as it has long term implications. The following should be aware of during contract formalisation:

- (i) In the process to approve outsourcing arrangements, prevailing government IT security requirements and related guidelines should be considered and included in the procurement specification.
- (ii) Document in the contracts the security requirements as defined by B/Ds. The contractors are obliged to define and implement security measures to meet those requirements. For example, requirements on data encryption and security standards on data destruction.
- (iii) The contract should include service level agreements which define the expected performance for each required security control, describe measurable outcomes, and identify remedies as well as requirements of response for any non-compliance incident. The agreements should also address liability issues, reliability of services and response times for the provision of services.
- (iv) Define and document the security roles and responsibilities of the service provider, internal staff and end-user pertaining to the outsourced information system.
- (v) B/Ds reserve the rights to audit responsibilities defined in the service level agreement and to have those audits carried out by independent third party. Document in the contract that the outsourcing contractor shall provide full cooperation and support in connection with these activities.
- (vi) Formalise the incident response procedures and management. A mechanism should be defined and established to report, notify, investigate and handle information security incidents or security breaches.
- (vii) The service provider should report to a nominated contact within B/D on an agreed timely basis and report all security related issues. An escalation process should be defined for incident handling, aiming to have fast response and appropriate problem solving in order to minimise the impact.
- (viii) Ensure that all related personnel from third party service providers and vendors, including but not limited to staff, directors, agents, associates or contractors, have signed non-disclosure agreements to protect sensitive data, for example:
 - Protect classified information from unauthorised use and disclosure, and hold all classified information in strict confidence.
 - Not to disclose classified information to any other third parties unless authorised. In case there are requests from other third party in requesting for classified information, the contractors shall immediately inform and redirect the requests to B/Ds for handling if such requests cannot be directly rejected.

- Promptly return or/and destroy all documentation, notes, diagrams, computer memory media and other materials containing any portion of the classified information and all hard copies or soft copies at the expiry or termination of the service or upon request of the Government.
- (ix) Ensure that contractors remain accountable for all actions of their subcontractors. In addition, make sure that the subcontractors are compatible to manage security and provide assurance to B/Ds in the agreed forms and procedures.
- (x) The contractor shall at its own expenses fix all identified security vulnerabilities and, with the request of the Government, conduct security risk assessment to ensure the system attains the required security level.

5. Monitoring Stage

In order to ensure compliance throughout the contract lifespan, an effective monitoring and review mechanism is essential for all outsourcing activities. B/Ds shall put in place a mechanism to check the compliance to government security requirements on data confidentiality.

- (i) The contract should provide review and audit mechanisms to ensure ongoing compliance with security requirements. Regular reviews on the security operations and corresponding access controls should be conducted to evaluate the service and make adjustments if necessary.
- (ii) Periodically monitor and review the compliance status of security controls managed by service providers. Regular audits shall be carried out by B/Ds or independent third party with statutory rights to ensure the compliance.
- (iii) Third party service providers might need access to privileged accounts, such as administrators of operating systems or database systems. Whenever they are granted with access, the usage and activities carried out with these privileged accounts should be monitored, logged and reviewed periodically.
- (iv) Establish control measures for requesting and approving program/system changes. Ensure all data to be handled by the outsourcing party is clearly and properly classified and protected. Access with security privileges should be assigned only on a need basis.
- (v) Maintain accurate and up-to-date inventory lists to ensure an effective and comprehensive monitoring on systems and data:
 - List of servers and systems within the scope of the project with information of sensitive or personal data stored;
 - List of support staff from third party service providers as well as the user ID and access privilege granted to individual support staff; and
 - List of data, especially sensitive or personal data, given to the third party service providers.
 - List of relevant documents, including valid warranties, service agreements and legal/contractual documents (e.g. public domain names registrations and related IP addresses, physical locations of data storage, etc.).
- (vi) B/Ds should well cater for on-going IT security and service management with contractors including but not limited to incident management, change management, configuration management (tracking all individual configuration items in IT systems), release management (distribution of software and hardware, quality control during development and implementation of new hardware and software), etc.
- (vii) Periodically check and review the list of persons who are gained access with authorisation to the location with computer equipment and data.

6. Transition Stage

At some point in time, it may have to cope with transition whether it is contract termination, changing service provider or returning to in-house. B/Ds should be well-prepared for the transition in order to maintain the security level and minimise the impact.

- (i) Ensure that the contractor returns to B/Ds with documents, files, procedures, configurations, drawings or records relating to the outsourced services. Upon project termination, all copies of information kept by the contractor should be securely destroyed or erased. There should also be written confirmation after such data destruction and erasures.
- (ii) Require an authority of the contractor to certify that destruction of information have been taken place securely and completely.
- (iii) Ensure that actions have been taken to terminate access rights or arrangements, such as all administrative accounts or passwords are disabled or reset, all remote management systems are disabled or deleted. Ensure that all access privileges on related information systems are terminated immediately after the staff is transferred or ceased to provide services.
- (iv) Ensure that a transition will be properly managed to minimise the disruption to services. It should be clearly defined how the service provider will work with the new service provider to transition outsourced IT systems in accordance with an agreed service termination process.
- (v) Conduct evaluation on the performance of the service provider so that any “lessons learned” will be incorporated into new arrangements or requirements in the contract. Update the requirements on internal policies and procedures if necessary.